

Checklist M1 · API nền + Auth

Dự án: Da Nang Connect — Giai đoạn 1 (MVP) · **Trạng thái chụp:** 19/09/2026 · **Ngày chốt:** 02/10/2026 · **Phân công:** 23/09/2026 (60-20-20)

Bản sửa được: docs/checklists/checklist-milestone-M0-M6.xlsx (mỗi phase một sheet, cột Trạng thái có danh sách chọn, sheet Tổng quan tự tính lại).

1. Cách đọc

Trạng thái:

-  **Xong:** đã làm và có bằng chứng (test, ảnh, link).
-  **Một phần:** đã có code hoặc cấu hình nhưng còn thiếu phần ghi ở cột Ghi chú.
-  **Chưa làm:** chưa bắt đầu. Đây là mặc định cho các mục M2-M6 chưa được kiểm tra chi tiết.
-  **Bị chặn:** phải chờ việc khác xong (ghi ở cột Ghi chú).
-  **Cần chốt:** cần quyết định của Founder, Product Owner, Tech Lead, BA hoặc luật sư trước khi làm.
-  **Chưa xác nhận:** việc ngoài repo (pháp lý, tài khoản, vận hành) chưa có bằng chứng; người phụ trách tự xác nhận.
-  **Cắt / hoãn:** ra khỏi phạm vi kịch bản tình gọn (cắt nhóm A + B, doc 08 §10.2); giữ lại để truy vết, không tính vào tỷ lệ xong.

Tỷ lệ xong = Xong / (Tổng – Cắt / hoãn).

Người phụ trách (QĐ-78, 23/09/2026 — chia khối lượng 60-20-20 theo chức năng, xem checklist-milestone-M0-M6.md §2.1):

- **Founder:** PO, Community Manager, curate, trực kiểm duyệt, quan hệ organizer, pháp lý, tài khoản cửa hàng và D-U-N-S, ký xác nhận người thứ hai (DoD-9). Không viết code.
- **TV1** (dùng AI, ~60%): Nền tảng và vòng lặp lỗi, kiêm Tech Lead — hạ tầng, CI/CD, deploy, trực sự cố, migration, design token, phân quyền và trust, sự kiện, khám phá, RSVP và waitlist, thông báo, đo lường sản phẩm.
- **TV2** (~20%): Tài khoản và hồ sơ — đăng ký, xác minh, đăng nhập, phiên, Google, đặt lại mật khẩu, hồ sơ và onboarding, ảnh và CDN, OTP, ngôn ngữ và i18n, tùy chọn thông báo, xuất/xoá dữ liệu, PWA, SEO toàn site.

- **TV3** (~20%): Vận hành — khu vực, kiểm duyệt (báo cáo, chặn, hàng đợi, xử lý, chống spam, Community Guidelines), Admin Console, curate và nhận quyền, tin tức do đội vận hành đăng, phiếu phân tích.
- **Thuê ngoài:** Designer (trọn gói 4 tuần), QA (2 đợt), dịch giả tiếng Việt.
- Mỗi thành viên làm trọn chức năng của mình: API, dữ liệu, màn web hoặc Admin Console, và E2E. Hai tên nối bằng "+" là việc chạm hai chức năng; người đứng đầu chịu trách nhiệm chính và nhận SP.

Nhóm việc trong mỗi phase: Việc chặn & cần chốt → Story → DoD bổ sung → Nghiệm thu → Demo → Việc ngoài SP → Bổ sung từ mockup → Bổ sung kịch bản tinh gọn.

Nguồn trạng thái: M0–M1 lấy từ đợt kiểm tra code chỉ đọc ngày 18/09/2026 (có đối chứng độc lập). Các mục "Một phần" của M2–M3 lấy từ ghi chú phiên làm việc 01–02/09, **chưa kiểm chứng lại bằng code**. Story, DoD, demo và tiêu chí nghiệm thu lấy nguyên văn từ docs/analysis/08–roadmap–va–ke–hoach–trien–khai.md §6–§7. Nhóm "Bổ sung từ mockup" là việc mới lộ ra từ bộ mockup web ngày 18–19/09 và quyết định của chủ dự án ngày 19/09. **Kịch bản đội:** CH-06 chốt ngày 19/09/2026 theo phương án tinh gọn, cắt nhóm A + B (QĐ-77); ngày 23/09/2026 đội code đổi thành 3 thành viên chia khối lượng 60-20-20 theo chức năng (QĐ-78). Ngày chốt M2–M6 và cột Sprint (L0–L12) theo 08 §10.4; người phụ trách theo QĐ-78; chữ của story, DoD, demo, nghiệm thu giữ nguyên văn, phần điều chỉnh tinh gọn ghi ở cột Ghi chú.

2. M1 · API nền + Auth — chốt 02/10/2026

Sprint: L1 · Tổng: 49 mục · 11 · 7 · 18 · 2 · 6 · 2 · 3 · Tỷ lệ xong: 24%

SP theo người (còn lại / trong phạm vi): TV1 3 / 8 · TV2 24 / 32 · TV3 0 / 0

Mục tiêu:

- L1 — 21/09 – 02/10/2026: Auth email + Google, refresh rotation, RBAC enum 5 role, trust_signals

Nếu trượt: M1 không được trượt. Đây là mắt xích đường găng cứng nhất phía kỹ thuật — toàn bộ E3, E4, E6 đều chờ nó. Trượt M1 thì trượt hết. Phương án khẩn: cắt E2-S5 (Facebook) và E2-S6 (đặt lại mật khẩu) sang S2, dồn 2 người vào E2-S2 và E2-S9. Tinh gọn: E2-S4 và E2-S5 đã cắt, E2-S9 đã hoãn và E2-S2 đã xong, nên phương án khẩn là dời E1-S9 (Sentry chỉ cần trước khi staging có người dùng thật, tức beta L10) và E2-S6 sang L2, dồn TV2 vào E2-S1 và E2-S3 (Google trên web), TV1 hỗ trợ E2-S1 khi xong phần L0 còn tồn.

2.1. Việc chặn & cần chốt

☐	Mã	Nội dung	Phụ trách	Trạng thái	Ghi chú / bằng chứng
☐	CH-01	Nghĩa vụ xác thực SĐT Việt Nam theo ND 147/2024: mọi tài khoản hay chỉ tài khoản đăng nội dung công khai.	Founder + Luật sư	Cần chốt	Hạn 21/09. Code đang ngầm chọn "không bắt buộc". Tinh gọn: Nếu bắt buộc cho mọi tài khoản thì dùng OTP của nhà cung cấp có sẵn (E3-S6 chỉ còn 2 SP, nhóm B)
☒	MT-17	Chốt tên guard/decorator trust và RBAC (code: TrustLevelGuard/@MinTrustLevel; doc: TrustTierGuard/@MinTrust).	TV1	Xong	Hạn 21/09; chặn E2-S7. Chốt 24/09/2026: giữ tên code TrustLevelGuard/@MinTrustLevel; guard mới là RolesGuard/@Roles, thứ tự JwtAuthGuard → RolesGuard → TrustLevelGuard (D-07: role trước trust). Kế hoạch và nghiệm thu: .agent/specs/_changes/rbac-admin-shell/.
☐	MT-16	user_status_enum 5 hay 8 giá trị (enum Postgres không xoá được giá trị).	TV2	Cần chốt	Hạn 02/10.
☒	PERM-MATRIX	Vị trí PERMISSION_MATRIX máy đọc được (doc 00: packages/shared-types; doc 01: apps/api/.../authz) + test describe.each T-1→T-5.	TV1	Xong	Hạn 21/09. Chốt 24/09/2026: packages/domain/src/permission-matrix.ts (STAFF_ROLES, SYSTEM_HEALTH_ROLES, PERMISSION_MATRIX), dùng chung cho RolesGuard ở API và menu/chặn route ở web admin; có unit test.

☐	Mã	Nội dung	Phụ trách	Trạng thái	Ghi chú / bằng chứng
☐	ADR-C9	Có tách schema identity_secret cho bảng xác thực mới không (ADR-0000 mục C9).	Founder + TV1	? Cần chốt	Hạn ký 07/09 đã qua. Tinh gọn: Founder ký ADR; TV1 đề xuất phương án và viết migration nếu chốt tách schema
☐	TOKEN-MOBILE	Một cơ chế trả refresh token dùng chung cho web (cookie), mobile (SecureStore) và social login; đổi hợp đồng packages/contracts.	TV2	? Cần chốt	Chặn E2-S3, E2-S4, E2-S9. Cổng phê duyệt: đổi packages dùng chung. Tinh gọn: Nhánh mobile (SecureStore) hoãn cùng E2-S9; chỉ cần chốt cookie cho web/PWA + Google, để hợp đồng mở sẵn cho bản native sau này
☐	BR-30	Nội dung Điều khoản / Chính sách quyền riêng tư và cơ chế consent_records (NĐ 13/2023 + Luật 91/2025).	Founder + Luật sư	? Cần chốt	Cần luật sư xác nhận. Tinh gọn: Founder soạn bản thảo mẫu, luật sư chỉ rà soát và ký xác nhận (gói pháp lý 55 triệu); vẫn phải theo Luật 91/2025
☐	ACC-APPLE-GOOGLE	Xác nhận tài khoản Apple Developer tổ chức / D-U-N-S; tạo Google OAuth client (3 ID: web, iOS, Android).	Founder + TV2	● Chưa xác nhận	Tinh gọn: Chỉ cần Google OAuth client cho web/PWA; không mua Apple Developer, D-U-N-S và 2 client iOS/Android thôi chặn vì E2-S4 bị cắt, bản native hoãn
☐	OWNERS	Gán người phụ trách cho T-10, T-11, T-12, T-14 trong ACTIVE_TASKS.	TV1	■ Chưa làm	Cột người phụ trách đang trống. Tinh gọn: Gán theo đội tinh gọn: T-10, T-11, T-12 cho TV2; T-14 cho TV1; T-11 chỉ còn Google
☒	INFRA-MAIL	Nối mail client (SMTP → Mailpit) dùng chung cho E2-S1 và E2-S6.	TV1	✅ Xong	Xong 24/09/2026: MailModule gửi qua SMTP (mặc định Mailpit), chặn người nhận theo MAIL_ALLOWED_DOMAINS cho staging, không ghi địa chỉ email vào log (e2e mail.e2e.spec.ts gửi thật và đọc lại từ Mailpit).
☒	INFRA-REDIS	Nối Redis client (ioredis / BullMQ) cho rate limit E2-S10 và job trust:recompute (T-13).	TV1	✅ Xong	Xong 24/09/2026: RedisModule có hai client (cache 6381, queue 6380 cấu hình sẵn cho BullMQ), kết nối lười, log khi mất và khi khôi phục kết nối, đóng sạch khi tắt app (enableShutdownHooks). Hàng đợi BullMQ tạo cùng E7-S1.
☐	SEC-JWT-LOG	Vá lỗi ghi khoá riêng JWT ra log debug khi thiếu JWT_PRIVATE_KEY (auth.service.ts:107), trước khi bật log tập trung.	TV2	■ Chưa làm	Lỗi bảo mật.
☐	T-14	Dựng Playwright ở apps/web-client-side/e2e/, chạy cả WebKit.	TV1	■ Chưa làm	Ba bug chỉ-có-ở-client đã lọt lưới. Tinh gọn: Không có QA thường trực: TV1 dựng khung, mỗi thành viên viết E2E cho chức năng của mình; QA thuê ngoài chỉ chạy 2 đợt trước beta và trước ra mắt

2.2. Story

☐	Mã	Nội dung	Phụ trách	Trạng thái	Ghi chú / bằng chứng
☐	E2-S1	Đăng ký email + xác minh email (8 SP) · MUST	TV2	🟡 Một phần	Đăng ký có nhưng cấp phiên + T1 ngay; chưa có token xác minh, endpoint verify, gửi mail (Mailpit đã chạy). Tinh gọn: Xác minh chỉ làm trên web/PWA; màn web do TV2 làm (MK-AUTH-02)
☒	E2-S2	JWT access 15 phút + refresh 30 ngày xoay vòng, phát hiện tái sử dụng (8 SP) · MUST	TV2	✅ Xong	Access 15 phút + refresh 30 ngày xoay vòng; test e2e "dùng lại token → thu hồi cả họ" (auth.e2e.spec.ts:323).
☐	E2-S3	Đăng nhập Google (5 SP) · MUST	TV2	🛑 Bị chặn	Chờ khung Expo (E1-S6), bảng social_accounts, endpoint /auth/social, Google OAuth client. Tinh gọn: Chỉ làm Google trên web/PWA, không còn chờ khung Expo (E1-S6 hoãn); vẫn chờ bảng social_accounts, endpoint /auth/social và OAuth client web
☐	E2-S4	Đăng nhập Apple (Guideline 4.8) (5 SP) · MUST	Founder	✂️ Cắt / hoãn	Như E2-S3, thêm tài khoản Apple Developer tổ chức / D-U-N-S. Tinh gọn: Cắt theo nhóm A: Guideline 4.8 chỉ áp dụng cho app trên App Store; giữ Google + email
☐	E2-S6	Đặt lại mật khẩu qua email (3 SP) · MUST	TV2	🟡 Chưa làm	Chưa có luồng quên / đặt lại mật khẩu. Tinh gọn: Màn quên/đặt lại mật khẩu trên web do TV2 làm (MK-AUTH-03); là việc dời đầu tiên nếu L1 quá tải
☒	E2-S7	Enum role toàn cục 5 giá trị + guard RBAC (5 SP) · MUST	TV1	✅ Xong	Enum 5 role đã đúng; chưa có RolesGuard/@Roles, chỉ có TrustLevelGuard. Tinh gọn: Thuộc danh sách không bao giờ cắt Xong 24/09/2026: thêm RolesGuard/@Roles và endpoint staff GET /api/v1/admin/system/health; 9 ca e2e admin-system-health.e2e.spec.ts. Kế hoạch và nghiệm thu: .agent/specs/_changes/rbac-admin-shell/.
☐	E2-S8	Màn đăng nhập/đăng ký web, trạng thái lỗi rõ ràng (5 SP) · MUST	TV2	🟡 Một phần	Màn đăng nhập/đăng ký web có; thiếu nhánh lỗi 429, locale đang viết cứng "en" (auth-form.tsx:85). Tinh gọn: Là màn đăng nhập duy nhất trên điện thoại (PWA thay app native), phải dùng tốt ở khổ màn hình mobile
☐	E2-S9	Giữ phiên trên mobile, token trong secure storage (8 SP) · MUST	Founder	✂️ Cắt / hoãn	Refresh token chỉ trả qua cookie httpOnly; phải chốt cơ chế cho mobile trước khi code. Tinh gọn: Hoãn theo nhóm A, 7 tháng đầu không có repo mobile; phiên trên web/PWA giữ bằng cookie httpOnly + refresh 30 ngày (E2-S2)
☐	E2-S10	Rate limit endpoint xác thực, chặn dò mật khẩu (3 SP) · MUST	TV2	🟡 Chưa làm	Chưa có rate limit; Redis đã chạy trong compose nhưng chưa nối client.
☐	E1-S9	Sentry + log tập trung (3 SP) · MUST	TV1	🟡 Chưa làm	Chưa có Sentry / log tập trung. Tinh gọn: Không có trong trọng tâm của 10.4 nhưng cũng không bị cắt; giữ ở L1 như §6.2

2.3. DoD bổ sung

☐	Mã	Nội dung	Phụ trách	Trạng thái	Ghi chú / bằng chứng
☐	S1-DoD-1	Migration tạo cột users.role kiểu enum đúng 5 giá trị chữ thường: member, curator, moderator, admin, super_admin. Mặc định member. Không có giá trị guest, organizer, verified_member, support trong enum — kiểm tra bằng một test đọc pg_enum và so khớp đúng 5 phần tử	TV1	🟡 Một phần	Enum đúng 5 giá trị; chưa có test đọc pg_enum.
☐	S1-DoD-2	Migration tạo cột users.trust_level kiểu smallint, CHECK (trust_level BETWEEN 0 AND 5), mặc định 0	TV1	🟡 Một phần	Cột có; đăng ký đang cấp thẳng T1 (TRUST_LEVEL_ON_REGISTER), phải về 0 khi có xác minh email.
☐	S1-DoD-3	Bảng trust_signals đã tạo (append-only), có REVOKE UPDATE, DELETE cho vai trò ứng dụng	TV1	🟡 Chưa làm	DDL đầy đủ đã có ở doc 03 §4.5, chỉ còn viết migration.
☒	S1-DoD-4	Test e2e luồng tái sử dụng refresh token: dùng lại token đã xoay → toàn bộ họ token của thiết bị đó bị thu hồi, trả 401	TV2	✅ Xong	auth.e2e.spec.ts:323.
☒	S1-DoD-5	Test guard: member gọi endpoint chỉ dành cho moderator → 403, không phải 404 và không phải 500	TV1	✅ Xong	Chưa có RolesGuard. Xong 24/09/2026: member gọi endpoint chỉ dành cho admin → 403 ROLE_NOT_ALLOWED (không 404/500), body không liệt kê role hợp lệ (e2e ca #2). Chưa có endpoint chỉ dành cho moderator nên test dùng endpoint admin.
☐	S1-DoD-6	Đăng nhập Apple chạy thật trên thiết bị iOS thật, không phải simulator	Founder	✂️ Cắt / hoãn	Chờ khung Expo + tài khoản Apple Developer. Tinh gọn: Chỉ dùng để kiểm Apple trên iOS native, mà E2-S4 đã bị cắt
☐	S1-DoD-7	Rate limit: 10 lần đăng nhập sai/IP/15 phút → 429 có header Ret ry-After	TV2	🟡 Chưa làm	—
☐	S1-DoD-8	Số đăng ký xử lý dữ liệu cá nhân đã có 3 dòng đầu: email, mật khẩu băm, định danh nhà cung cấp social	Founder + TV2	🟡 Chưa làm	Phụ thuộc DoD S0 số đăng ký. Tinh gọn: Dòng định danh nhà cung cấp social chỉ còn Google (Apple, Facebook đã cắt); TV2 cung cấp danh sách trường dữ liệu

2.4. Nghiệm thu

☐	Mã	Nội dung	Phụ trách	Trạng thái	Ghi chú / bằng chứng
☐	M1-1	Đăng ký + xác minh email chạy end-to-end trên web và mobile	TV2	🟡 Một phần	Web có đăng ký nhưng chưa có xác minh email; mobile chưa có. Bằng chứng: Video 2 nền tảng. Tinh gọn: Phần mobile nghiệm thu bằng trình duyệt điện thoại/PWA thay app native; quay video trên desktop + điện thoại

☐	Mã	Nội dung	Phụ trách	Trạng thái	Ghi chú / bằng chứng
☐	M1-2	Đăng nhập Google và Apple chạy trên thiết bị thật, không phải simulator	TV2	🛑 Bị chặn	Bằng chứng: Video thiết bị. Tinh gọn: Chỉ còn Google trên Android và iPhone thật qua trình duyệt/PWA; phần Apple bị cắt theo E2-S4
☒	M1-3	Refresh token rotation có test e2e, gồm ca tái sử dụng token đã xoay → thu hồi cả họ	TV2	✅ Xong	Bằng chứng: Báo cáo test
☐	M1-4	users.role là enum đúng 5 giá trị member/curator/moderator/admin/super_admin; không có guest, organizer, verified_member, support	TV1	🟡 Một phần	Thiếu test pg_enum. Bằng chứng: Test đọc pg_enum
☒	M1-5	Guard RBAC chặn đúng: member gọi endpoint moderator → 403	TV1	✅ Xong	Bằng chứng: Test e2e Đạt 24/09/2026: curator/moderator/member → 403, admin/super_admin → 200 (e2e ca #2-6).
☐	M1-6	users.trust_level smallint 0-5 đã có, mặc định 0; bảng trust_signals append-only đã có	TV1	🟡 Một phần	trust_signals chưa có. Bằng chứng: Migration + kiểm tra quyền
☐	M1-7	Rate limit endpoint xác thực hoạt động, trả 429 có Retry-After	TV2	🟡 Chưa làm	Bằng chứng: Kịch bản test
☐	M1-8	Sổ đăng ký hoạt động xử lý dữ liệu cá nhân đã mở, có ≥ 3 mục	Founder + TV2	🟡 Chưa làm	Bằng chứng: File sổ đăng ký

2.5. Demo

☐	Mã	Nội dung	Phụ trách	Trạng thái	Ghi chú / bằng chứng
☐	S1-Demo-1	Trên web: đăng ký bằng email thật → nhận mail xác minh → bấm xác minh → vào được khu vực đã đăng nhập	TV2	🟡 Chưa làm	—
☐	S1-Demo-2	Trên iPhone thật: đăng nhập bằng Apple ID → đóng app hoàn toàn → mở lại sau 10 phút → vẫn đăng nhập	TV2	🟡 Chưa làm	Tinh gọn: Bỏ phần Apple ID vì E2-S4 đã cắt; vẫn demo trên iPhone thật qua Safari: đăng nhập email/Google → đóng hẳn trình duyệt → mở lại sau 10 phút → vẫn đăng nhập (cookie httpOnly + refresh 30 ngày của E2-S2, TV2 cấu hình cookie); bản thêm vào màn hình chính kiểm lại ở L9
☐	S1-Demo-3	Trên Android thật: đăng nhập Google một chạm	TV2	🟡 Chưa làm	Tinh gọn: Demo qua Chrome/PWA trên Android thật (Google một chạm trên web), không cần app native

☐	Mã	Nội dung	Phụ trách	Trạng thái	Ghi chú / bằng chứng
☐	S1-Demo-4	Demo bảo mật: lấy refresh token cũ trong Postman gọi lại → cả họ token bị thu hồi, thiết bị bị đá ra	TV2	Chưa làm	Tinh gọn: Bước 'thiết bị bị đá ra' minh hoạ bằng phiên trình duyệt/PWA
☒	S1-Demo-5	Demo RBAC: đổi role của tài khoản demo trong DB từ member sang moderator → endpoint kiểm duyệt mở ra ngay lần gọi kế tiếp	TV1	Xong	Đạt 24/09/2026, cách demo đúng: đổi role trong DB → gọi bằng token cũ vẫn 403 (role nằm trong JWT) → refresh hoặc đăng nhập lại → 200. Dùng cặp member → admin qua GET /api/v1/admin/system/health (e2e ca #7–8).

2.6. Việc ngoài SP

☐	Mã	Nội dung	Phụ trách	Trạng thái	Ghi chú / bằng chứng
☐	S1-Ops-0	theo dõi hồ sơ D-U-N-S; nếu quá 14 ngày chưa có kết quả thì mở ticket với Dun & Bradstreet — đây là ngưỡng cảnh báo đường găng đầu tiên.	Founder	Chưa xác nhận	Tinh gọn: Không còn là ngưỡng đường găng vì bỏ Apple Developer và hoãn E12; chỉ theo dõi để giữ đường cho bản native sau ra mắt

2.7. Bổ sung từ mockup

☐	Mã	Nội dung	Phụ trách	Trạng thái	Ghi chú / bằng chứng
☐	MK-AUTH-01	Chốt form đăng ký theo UC-01: 3 trường, mật khẩu ≥ 10 ký tự + 4 điều kiện, 2 ô đồng ý tách riêng không tích sẵn, không báo "email đã tồn tại". Code hiện có trường handle, mật khẩu ≥ 12 , trả EMAIL_TAKEN.	Founder + TV2	Cần chốt	—
☐	MK-AUTH-02	Màn "Check your inbox": mã 6 số, gửi lại sau 60 giây (tối đa 5 lần / 24 giờ), đổi email 1 lần, khoá 15 phút sau 5 lần sai; trang link thành công / hết hạn / đã dùng / mở trên máy khác.	TV2	Chưa làm	—
☐	MK-AUTH-03	Đặt lại mật khẩu: màn gửi mail trung tính (không lộ email), đăng xuất mọi phiên khác sau khi đổi.	TV2	Chưa làm	—
☐	MK-AUTH-04	Social login: màn "email này đã có tài khoản — đăng nhập để liên kết", không tự hợp nhất.	TV2	Chưa làm	Tinh gọn: Chỉ còn Google trên web/PWA; Apple và Facebook đã cắt nên không còn nhánh mobile native